



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



FatFs Embedded Filesystem Vulnerabilities in IoT and OT Devices

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-07-05
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | FatFs Embedded Filesystem Vulnerabilities in IoT and OT Devices - CVE / Vulnerability Threat Intelligence Report

Published: 2026-07-05 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

FatFs Embedded Filesystem Vulnerabilities in IoT and OT Devices

1. Executive Summary

runZero disclosed seven vulnerabilities in ChaN's FatFs filesystem library, a small embedded FAT/exFAT implementation that is widely bundled into IoT, OT, drone, embedded Linux-adjacent, firmware-update, and real-time operating system environments. Public reporting identifies the CVE range as CVE-2026-6682 through CVE-2026-6688, with the highest-severity issues rated 7.6 and affecting FAT32/exFAT parsing, mount logic, file-size metadata handling, and common downstream wrapper patterns.

Defenders should prioritize this cluster because the vulnerable component is not a conventional centrally patched enterprise package. FatFs is often copied into firmware trees, SDKs, bootloaders, update processes, removable-media handlers, and vendor BSPs. The same flaw can therefore persist across security cameras, drones, industrial controllers, hardware wallets, avionics-adjacent embedded tooling, lab equipment, and supplier-maintained devices long after the upstream disclosure.

The immediate defensive objective is asset discovery and exposure reduction rather than a single universal patch. Identify products that parse FAT/exFAT media or firmware images, ask vendors whether FatFs R0.16 or earlier is present, restrict untrusted removable media and update packages, and monitor for suspicious mount/update crashes or repeated malformed-media handling.

2. Vulnerability Metadata

Field	Value
Primary CVEs	CVE-2026-6682; CVE-2026-6687; CVE-2026-6688
Additional CVEs	CVE-2026-6683; CVE-2026-6684; CVE-2026-6685; CVE-2026-6686
Product / Component	ChaN FatFs R0.16 and earlier; downstream embedded products bundling FatFs
Weakness	Integer overflow, memory corruption, divide-by-zero, parser hangs, unsafe downstream wrapper handling
Severity	Medium to High; public reporting lists three high-severity 7.6 issues
Affected Versions	FatFs R0.16 and earlier, plus embedded products and SDKs that copied vulnerable code
Fixed Versions	Upstream fix reported for the GPT hang in FatFs R0.16; other memory-corruption issues require downstream vendor remediation at time of reviewed reporting
Disclosure Date	runZero disclosure reported 2026-07-01; public reporting 2026-07-03/04
Exploitation Status	Public PoC/test images and harnesses reported; no confirmed in-the-wild exploitation in reviewed sources

3. Source Review & Confidence

Source	Contribution	Confidence
runZero research and advisory pages	Primary technical source for affected component, CVE descriptions, exploit	High

	preconditions, and downstream blast radius	
NVD / CVE entry for CVE-2026-6682	Confirms the leading integer-overflow description and affected FatFs R0.16-and-earlier scope	High
The Hacker News and cybersecurity press summaries	Independent context on affected ecosystems, public PoC availability, absence of observed exploitation, and patching challenges	Medium

Confidence is high that the FatFs vulnerability cluster is real and broad because primary researcher advisories and CVE/NVD records are available. Confidence is medium for exact product-by-product exposure because FatFs is frequently vendored into firmware without transparent software bills of materials. Organizations should treat product impact as a discovery task until vendors confirm their embedded library lineage.

4. Vulnerability Details

The highest-priority issue, CVE-2026-6682, is described by NVD and runZero as an integer overflow in `mount_volume()` where `fsize *= fs->n_fats` can wrap. That can produce attacker-controlled file-size metadata and unsafe read lengths in downstream callers. Other issues in the cluster involve malformed FAT/exFAT volumes, long filenames, update-flow edge cases, divide-by-zero conditions, and GPT partition-table parsing hangs.

The attack precondition is often deceptively simple: the device parses a malformed storage volume, removable medium, SD card, USB device, disk image, or firmware-update package. The operational consequence varies by product. Some devices may crash or hang; others may expose memory-corruption paths in wrappers around FatFs, especially where vendors copy file names or file-size fields into fixed buffers or trusted update routines.

5. Attack Scenarios

- **Malicious removable media:** An attacker with physical or supply-chain access inserts a crafted SD card or USB device into embedded equipment that automatically mounts FAT/exFAT volumes.
- **Firmware/update package abuse:** A device update flow processes a malformed FAT filesystem image, causing a crash, brick, or memory-corruption path in downstream updater logic.
- **Drone, robotics, or aviation-support workflow exposure:** Maintenance workflows that move data by SD card or removable media parse attacker-crafted volumes on ground-station, MRO, or lab equipment.
- **Supplier-delivered embedded product risk:** A vulnerable SDK copy is buried inside an OEM product, making normal OS package scanning ineffective.

6. Threat Landscape & Exploitation Status

Reviewed sources report public PoC/test material but no confirmed exploitation. The risk is nonetheless material because exploitation can be local, physical, or supply-chain mediated and may not produce conventional network indicators. FatFs' distribution model also resembles previous embedded-library disclosure events where downstream remediation took months or years.

Signal	Assessment	Defender Implication
Public CVE range and PoC artifacts	Exploit knowledge is available to researchers and attackers	Do not wait for observed exploitation before inventorying exposure
Embedded-library distribution	Product exposure is hidden in firmware and SDK copies	Use vendor questionnaires, SBOMs, firmware analysis, and procurement pressure
Removable media/update vector	Many attacks may be local or maintenance-path based	Strengthen media handling, update signing, and lab/MRO procedures

One partial upstream fix	GPT hang fix does not resolve the full cluster	Track each CVE and downstream vendor fixes separately
--------------------------	--	---

7. Affected Products and Exposure

Exposure Pattern	Why It Matters
Devices using FatFs R0.16 or earlier	Primary vulnerable code base
IoT and industrial controllers with USB/SD/FAT support	Malformed removable media can trigger parser behavior
Firmware update and OTA packages containing FAT images	Update flow may process attacker-controlled filesystem metadata
Drones, robotics, avionics-adjacent maintenance tools, and MRO workflows	Operational environments frequently move data via removable media and embedded devices
Products without SBOM or vendor transparency	Exposure may be invisible to enterprise vulnerability scanners

8. Mitigation and Workarounds

1. Inventory products and firmware that parse FAT, FAT32, or exFAT media, with priority on OT, IoT, aviation-support, drone/robotics, security, and update infrastructure.
2. Ask vendors whether they bundle ChaN FatFs, which version they use, and whether they have reviewed CVE-2026-6682 through CVE-2026-6688.
3. Restrict untrusted removable media. Use controlled media, scanning kiosks, media provenance controls, and write-block/format procedures in maintenance workflows.
4. Require signed firmware/update packages and validate update images before devices parse them.
5. Patch or upgrade affected SDKs and firmware when vendor updates become available; track the GPT hang fix separately from unresolved memory-corruption issues.
6. Monitor for repeated device crashes, mount failures, update failures, or watchdog resets following removable-media insertion or update attempts.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Repeated removable-media mount failures	Linux syslog, embedded device logs, EDR DeviceEvents	Identify malformed FAT/exFAT parsing attempts
Firmware/update process crashes after media access	EDR, syslog, application logs	Surface exploitation or bricking attempts
Unusual USB/SD activity on maintenance workstations	DeviceEvents, MDM, EDR	Detect unauthorized media introduction into sensitive workflows

9.2. Sigma / Detection Rule

```

title: Suspicious FAT or exFAT Mount Failures on Maintenance Systems
id: 23f7157a-9d58-49cf-9d30-fatfs-mount-failure
status: experimental
description: Detects repeated FAT/exFAT mount or filesystem errors that may indicate malformed media used to trigger FatFs-class parsing vulnerabilities.
logsource:
  product: linux

```

```

service: syslog
detection:
  selection_fs:
    Message|contains:
      - 'FAT-fs'
      - 'exFAT'
      - 'mount_volume'
      - 'Volume was not properly unmounted'
      - 'invalid FAT'
      - 'bogus number of reserved sectors'
  selection_repeat:
    Message|contains:
      - 'error'
      - 'failed'
      - 'invalid'
      - 'corrupt'
  condition: selection_fs and selection_repeat
fields:
  - Hostname
  - Timestamp
  - Message
level: medium

```

9.3. Hunt Query

```

DeviceEvents
| where Timestamp > ago(30d)
| where ActionType has_any ('UsbDriveMounted', 'PnpDeviceConnected', 'RemovableStoragePolicyTriggered')
| summarize MediaEvents=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp),
Devices=make_set(DeviceName, 25) by InitiatingProcessAccountName, AdditionalFields
| where MediaEvents > 5
| order by LastSeen desc

```

10. Threat Hunting

10.1. Hunt Hypothesis

If adversaries test FatFs-class bugs in an enterprise or aviation-support environment, the first observable signs will be unusual removable-media insertions, repeated mount/update errors, or crashes of maintenance/update tools rather than network beacons.

10.2. Hunt Query

```

DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ ('mount', 'udisksd', 'fwupdmgr', 'dfu-util', 'qemu-system-arm', 'qemu-system-aarch64')
  or ProcessCommandLine has_any ('fat', 'exfat', 'firmware', 'sdcard', 'usb', 'update.img')
| summarize Count=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp),
Commands=make_set(ProcessCommandLine, 20) by DeviceName, InitiatingProcessAccountName, FileName
| where Count > 3
| order by LastSeen desc

```

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1091	Replication Through Removable Media	Primary exposure involves malformed removable media or filesystem images
T1200	Hardware Additions	Physical insertion of USB/SD media is a realistic trigger path
T1195	Supply Chain Compromise	Vulnerable library copies may be inherited

		from SDKs, BSPs, or suppliers
T1499	Endpoint Denial of Service	Several issues can crash, hang, or brick devices depending on downstream handling
T1608	Stage Capabilities	Public PoC images/harnesses lower attacker setup cost

12. Validation / Lab Testing

No exploit reproduction was performed. Validation included review of runZero and public reporting, CVE/NVD descriptions, and construction of detection logic focused on maintenance endpoints and embedded-device logs. Organizations should test detection content in lab environments because embedded devices may emit vendor-specific log messages and may not forward detailed FatFs errors to a SIEM.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Asset / OT Engineering	Identify devices and firmware workflows that parse FAT/exFAT media or include FatFs
High	Vendor Management	Request vendor confirmation for CVE-2026-6682 through CVE-2026-6688 and remediation timelines
High	Operations / MRO	Restrict removable-media use to controlled, scanned, and procedurally approved media
Medium	Detection Engineering	Deploy mount/update failure hunts on maintenance workstations and Linux/embedded log collectors
Medium	Procurement	Require SBOM and embedded-library disclosure for devices entering critical workflows

14. References

- [1] runZero, "Seven FatFs bugs, one very large blast radius": <https://www.runzero.com/blog/fatfs-bugs/>
- [2] runZero advisory, "FatFS FAT32 integer overflow in mount_volume() - CVE-2026-6682": <https://www.runzero.com/advisories/fatfs-fat32-int-of-mnt-cve-2026-6682/>
- [3] NVD, "CVE-2026-6682": <https://nvd.nist.gov/vuln/detail/CVE-2026-6682>
- [4] The Hacker News, "Unpatched Flaws Disclosed in Filesystem Bundled Into Millions of Embedded Devices": <https://thehackernews.com/2026/07/unpatched-flaws-disclosed-in-filesystem.html>
- [5] Cybersecurity News, "Multiple FatFs Vulnerabilities Expose Millions of Embedded Devices": <https://cybersecuritynews.com/fatfs-vulnerabilities/>